
Definire i diversi tipi di dato con vulnerabilità e minacce ad essi associate e tipi di Dato secondo il GDPR

Dato Personale: Qualsiasi informazione che riguarda una persona fisica identificata o identificabile, direttamente o indirettamente. Rientrano in questa categoria il nome, i numeri di identificazione, i dati di localizzazione (come l'indirizzo IP), e gli identificatori online.

Dati Sensibili (Categorie particolari): Dati che richiedono maggiore tutela, come l'origine razziale o etnica, le opinioni politiche, le convinzioni religiose o filosofiche, l'appartenenza sindacale, i dati genetici e biometrici, lo stato di salute e le informazioni sulla vita o l'orientamento sessuale.

Dati Giudiziari: Informazioni relative a condanne penali, reati, o connesse misure di sicurezza, inclusi i provvedimenti del casellario giudiziario e la qualità di imputato o indagato.

Dati Pseudonimizzati: Dati trattati in modo tale da non poter essere più attribuiti a un soggetto specifico senza l'uso di informazioni aggiuntive, le quali devono essere conservate separatamente e in sicurezza.

Dati Anonimi: Dati sottoposti a un processo irreversibile che impedisce definitivamente l'identificazione della persona.

Vulnerabilità e Minacce (Data Breach)

Le vulnerabilità si concretizzano principalmente nei Data Breach (violazioni dei dati), definiti come violazioni di sicurezza che comportano distruzione, perdita, modifica, divulgazione non autorizzata o accesso accidentale/illecito ai dati.

Violazione di Riservatezza (Confidentiality): Avviene in caso di divulgazione o accesso non autorizzato o accidentale. Una minaccia tipica è l'accesso abusivo alle e-mail dei dipendenti o il dirottamento di sessione.

Violazione di Integrità (Integrity): Consiste nell'alterazione accidentale o non autorizzata dei dati personali.

Violazione di Disponibilità (Availability): Si verifica con la perdita, inaccessibilità o distruzione dei dati. Un esempio di minaccia diretta in questo caso sono gli attacchi ransomware.

Attacchi di De-anonimizzazione: Anche i dati apparentemente resi anonimi o aggregati sono vulnerabili se incrociati con altri set di dati o fonti pubbliche (come i social media) per re-identificare le persone. Minacce specifiche includono attacchi tramite cache side-channel sui browser o il tracciamento tramite URL specifici.

2) In seguito ad un data breach in un ambiente critico, definire un'analisi e gestione del rischio in conformità al GDPR

In caso di violazione dei dati (Data Breach) in ambienti critici, l'analisi e la gestione del rischio devono seguire direttive precise:

Analisi del Rischio e Obbligo di Notifica (Art. 33 GDPR): Il titolare del trattamento deve notificare la violazione all'autorità di controllo (Garante) entro 72 ore dal momento in cui ne viene a conoscenza, qualora la violazione comporti ragionevolmente un rischio per i diritti e le libertà delle persone fisiche.

Comunicazione all'Interessato: Se dall'analisi emerge che il rischio per gli individui è "elevato", il titolare deve comunicare la violazione anche ai soggetti interessati. Un'eventuale mancata notifica può essere interpretata dall'autorità come sintomo di inadeguatezza delle misure di sicurezza.

Gestione in Ambienti Critici (Direttiva NIS): Per le infrastrutture critiche nazionali e gli operatori di servizi essenziali, la Direttiva NIS impone obblighi vincolanti per la sicurezza e la segnalazione degli incidenti.

Fasi di Gestione dell'Incidente:

Detect & Respond (Rilevamento e Risposta): Rilevare le anomalie in modo tempestivo, condurre analisi per comprendere l'impatto e intraprendere azioni di mitigazione per prevenire l'espansione dell'evento.

Comunicazione: Coordinare le attività di risposta con stakeholder interni ed esterni, inclusi CSIRT/CERT, fornitori di servizi e forze dell'ordine.

Recover (Ripristino): Eseguire i processi di ripristino per garantire la ripresa tempestiva dei sistemi compromessi e implementare i miglioramenti basati sulle lezioni apprese.

Utilizzo di Standard Esistenti: Invece di "reinventare la ruota", l'organizzazione deve affidarsi a framework ISO già consolidati per gestire queste fasi in conformità al GDPR, come la ISO 27035 per la gestione degli incidenti di sicurezza e la ISO 22301/22317 per la business continuity.

3) Spiegare la differenza tra privacy e protezione in cybersecurity

Sebbene strettamente collegati, i concetti di Data Protection e Data Privacy hanno scopi e definizioni distinte:

Data Protection (Protezione dei dati): È definita come il processo volto a salvaguardare informazioni importanti da corruzione, compromissione o perdita. Questo processo include meccanismi tecnici come le procedure di backup e ripristino, e i controlli sulla sicurezza e sull'integrità dei dati. In pratica, la protezione dei dati fornisce gli strumenti e le policy per difendere e mettere in sicurezza le informazioni.

Data Privacy (Privacy delle informazioni): È definita come il processo di gestione di specifiche tipologie di dati (come le informazioni personali identificabili - PII - o i dati sanitari protetti - PHI) per assicurare che non vengano utilizzati in modo improprio. A differenza della protezione che blinda il dato, la privacy si occupa di restringere e regolamentare l'accesso ai dati sensibili basandosi sul consenso, sulle finalità di utilizzo e sui diritti dell'interessato